

IOC (Indicator of Compromise)

IOC, bir saldırının gerçekleştiğine dair somut ve aranabilir bir iz. Bir IP adresi, alan adı, dosya hash'i, dosya adı, e-posta adresi ya da ele geçirilmiş bir kullanıcı adı olabilir. Bir olayı incelerken ortaya çıkarılan bu göstergeler temiz bir liste haline getirilir. Bunun amacı, bulunan bir kanıtın tek bir olayla sınırlı kalmaktan çıkarılıp tüm ortamda aranabilir bir ölçüte dönüştürmek. Yani "bu saldırgan başka nerede iz bıraktı?" sorusunu sorabiliyoruz.

Örnek (Case 1 üzerinden):

Case 1 IOC listesi:

Kaynak IP: 203.0.113.66

Ele geçirilen meşru hesap: deploy

Saldırganın oluşturduğu yeni hesap: svc-update

Bu göstergeler tüm ağ loglarında aratılırsa, aynı IP'nin başka hangi sistemlere dokunduğu ya da svc-update hesabının başka nerede kullanıldığı görülebilir.

Neden analist için önemli?

IOC olmadan her bulgu tek bir olayın içinde hapsolür. IOC listesi çıkarınca bu bilgi kalıcı ve tekrar kullanılabilir hale geliyor; yeni bir olayda ya da geçmişe dönük bir taramada aynı göstergeler aranarak saldırganın izi tüm ortamda sürülebilir.

IOC Türleri ve Pyramid of Pain

Farklı IOC türlerinin saldırgan tarafından değiştirilme kolaylığı farklı, ve bu kolaylık o göstergenin tespitteki değerini belirliyor. Bu fikri David Bianco'nun Pyramid of Pain kavramı açıklıyor: piramidin altında, saldırganın en kolay değiştirebildiği göstergeler var: IP adresi ve alan adı gibi. Bunları değiştirmek saldırganı neredeyse hiç maliyet çıkarmıyor, bu yüzden zayıf ve kısa ömürlü göstergeler. Biraz daha yukarıda dosya hash'i var; bunu değiştirmek (dosyayı yeniden derlemek gibi) biraz daha zahmetli. Piramidin en tepesinde ise saldırganın davranışı, yani kullandığı teknikler (TTP - Tactics, Techniques, Procedures) var. Bir saldırganın taktiğini ve tekniğini değiştirmesi gerçekten zor, çünkü bu onun çalışma biçiminin, alışkanlıklarının bir parçası.

Örnek:

Case 1'de saldırgan 203.0.113.66 IP'sini kullandı. Ben bu IP'yi engellesem, saldırgan yeni bir IP'den devam edebilir. Ama saldırganın kullandığı davranış - kaba kuvvetle giriş deneyip başarılı olduktan sonra sudo cat /etc/shadow ile credential access yapıp yeni bir hesap açması - bu deseni tespit edip alarm kurarsam, saldırgan hangi IP'den gelirse gelsin bu davranışı sürdürdüğü sürece yakalanır.

Neden analist için önemli?

Bu yüzden hem IOC (hızlı, somut ama kolay değiştirilebilir) hem de MITRE ATT&CK teknikleri (kalıcı, davranışsal, değiştirmesi zor) birlikte kullanılıyor. Yalnızca IOC'lere dayanan bir tespit, saldırgan altyapısını değiştirdiği anda işlevsiz kalır; davranışa odaklanan bir tespit ise saldırganı gerçekten zorlar, çünkü tekniğini değiştirmesi çok daha maliyetli.

MITRE ATT&CK Teknik Eşlemesi

ADIM	TEKNİK	ID	TAKTİK
Kaba kuvvetle SSH giriş denemeleri (91 başarısız deneme)	Brute Force	T1110	Credential Access
Ele geçirilen meşru deploy hesabıyla başarılı giriş	Valid Accounts	T1078	Initial Access
sudo cat /etc/shadow ile parola hash'lerini okuma	OS Credential Dumping: /etc/passwd and /etc/shadow	T1003.008	Credential Access
useradd svc-update ile yeni hesap oluşturma	Create Account: Local Account	T1136.001	Persistence

Neden analist için önemli?

Teknik ID'ler, taktik isminden daha spesifik ve standart bir dil sağlıyor. "kaba kuvvet" demek yerine T1110 dendiğinde, bu ister Splunk'ta ister başka bir SIEM'de ister farklı bir ekipte olsun herkes aynı şeyi anlıyor. Ayrıca raporun MITRE Navigator gibi araçlarla görselleştirilebilmesini ve geçmiş olaylarla karşılaştırılabilmesini sağlıyor.

Çok Kaynaklı İz Sürme Mantığı

Bir olayı incelerken tek bir log kaynağı genelde yeterli olmuyor, birden fazla kaynak bir arada değerlendirilmesi gerekiyor ve olay hiçbir kaynakta tek başına durmuyor. Temel mantık şu: bir kaynakta bulunan bir gösterge (IOC), diğer kaynağa açılan bir kapı niteliğinde. Yani bir göstergiyi bir kaynaktan alıp diğerine taşıyarak zincir halka halka örülüyor.

Örnek:

Bir firewall logunda kötücül bir IP görülürse, o IP süreç loglarında aratılıp "hangi program bu IP'ye bağlandı" sorusu cevaplanır. Bir kullanıcı adı bulunursa (mesela deploy), bu hesap hem Windows hem Linux loglarında aratılıp saldırganın nereye kadar gittiği izlenir. Sürekli sorulması gereken soru: "elimizdeki bu gösterge - bu IP, bu hesap, bu dosya, bu zaman - başka hangi kaynakta geçiyor?"

Neden analist için önemli?

Sorunun ticket olarak gelip numaralandırılmamış olduđu durumlarda, hangi soruların sorulacađının da analist tarafından belirlenmesi gerekiyor. Bu yüzden bulunan bir göstergeyi pasif bırakmayıp aktif şekilde diđer kaynaklarda aramak, olayın tam kapsamını (hangi sistemlere dokunulduđunu) ortaya çıkarmanın tek yolu. Aksi halde olay tek bir log dosyasının içine hapsolmuş, eksik bir hikaye olarak kalır.